

IMPLEMENTING A SECURE NETWORK ARCHITECTURE FOR A LARGE ENTERPRISE

Segmented Multi-Department Network with Firewall, VPN, DNS & Security
Testing

Platform: VMware Workstation | Firewall/Router: OPNsense | Clients: Ubuntu Server, Kali Linux

Project Report by K AJAY KRISHNA

Table of Contents

Table of Contents.....	2
1. Executive Summary	4
2. Project Environment Setup.....	4
3. OPNsense Installation and Configuration	4
4. Virtual Network Design.....	5
5. DHCP Configuration.....	5
6. Troubleshooting Network Interface Mapping	6
7. Network Segmentation — VLAN Design and Access Control Lists (Firewall Rules)	6
7.1 Implementation Approach.....	7
7.2 Rule Summary by Interface	7
8. Connectivity Verification	7
9. Enterprise Web Server Deployment	8
10. NAT / Port Forwarding.....	8
11. Secure Remote Access — VPN Configuration (WireGuard) and Zero Trust Considerations	9
11.1 Server-Side Configuration.....	9
11.2 Zero Trust Considerations	10
12. Unbound DNS Configuration.....	11
13. Perimeter Security Validation — IDPS Evaluation and Security Testing with Kali Linux	12
13.1 Intrusion Detection and Prevention (IDPS)	12
13.2 Security Testing Methodology.....	12
13.3 Host Discovery Scans.....	12
13.4 Port-Level Scan	14
14. Identity and Access Management (IAM) Plan.....	13
14.1 Multi-Factor Authentication (MFA)	13
14.2 Role-Based Access Control (RBAC).....	13
15. Endpoint Security Plan	14
16. Data Encryption Strategy	14
16.1 Encryption in Transit.....	14
16.2 Encryption at Rest	14
17. Monitoring and Logging Plan.....	15
18. Policy and Compliance Documentation	15
18.1 Security Policy Summary.....	15
18.2 Regulatory Compliance Checklist	16
19. Incident Response Plan	16
19.1 Incident Response Process	16

19.2 Incident Response Drill Scenario	17
20. Conclusion	17
20.1 Summary of Outcomes	17
20.2 Key Technical Achievements.....	17
20.3 Challenges Encountered	17
20.4 Limitations and Recommended Next Steps	17
21. References.....	18

1. Executive Summary

This report documents the end-to-end design, implementation, and testing of a segmented enterprise network for a fictional organisation with six departments: HR, Finance, IT, Server, Guest, and Management. The network was built in a fully virtualised lab environment using VMware Workstation, with OPNsense acting as the core firewall/router and Ubuntu-based client machines representing department endpoints. The project covers network segmentation, DHCP provisioning, firewall-based access control, an internally hosted enterprise web/file/database server, NAT port forwarding, a WireGuard VPN for remote employees, internal DNS resolution via Unbound, and security validation using Kali Linux.

The completed build demonstrates the following core capabilities:

- Six isolated department subnets, each with its own firewall interface
- DHCP-assigned addressing per department via OPNsense's Dnsmasq service
- A least-privilege firewall rule set enforcing a defined department access matrix
- An internal enterprise server running Apache (web), MySQL (database), and Samba (file sharing)
- NAT/port forwarding to publish the web server outward
- A WireGuard VPN instance for secure remote employee access
- Internal DNS resolution via Unbound, including a custom host override
- Security validation using Nmap from a Kali Linux attack host, confirming segmentation holds under active scanning

2. Project Environment Setup

The lab environment was built entirely in VMware Workstation. Two core virtual machines were created: an OPNsense virtual machine acting as the network's firewall/router, and Ubuntu virtual machines representing endpoint clients for each department. Additional interfaces (virtual NICs) were added to the OPNsense VM to represent each department's network segment, and corresponding custom VMnets were configured in VMware's Virtual Network Editor to physically separate the traffic for each department.

Six department interfaces were defined: HR, Finance, IT, Server, Guest, and Management, each mapped to its own VMnet and given a distinct private subnet in the 10.10.x.0/24 range.

3. OPNsense Installation and Configuration

OPNsense was installed as the core firewall/router for the network. The WAN interface was configured to obtain its address via DHCP (representing the organisation's uplink), while each department interface (HR, Finance, IT, Server, Guest, Management) was assigned a static gateway address on its own /24 subnet.

Status	Interface	Device	VLAN	Link Type	IPv4	IPv6	Gateway	Routes	Commands
🟢	WAN (wan)	em0		dhcp	192.168.1.6/24	2001:4490:4c95:850b:20c 2001:4490:4c95:850b:1/: fe80::1 2409:40f0:dc9e4:20c:29f 2001:4490:4c95:95cc:20c fe80::20c:29ff:fe41:497b/	192.168.1.1 fe80::1	default 192.168.1.0/24 default 2001:4490:4c95:850b::/64 2001:4490:4c95:95cc::/64 2001:4490:efd4::4 2001:4490:efe0:600::4 2409:40f0:dc9e4::/64 fe80::%em0/64 fe80::1%em0	🔄 ⚙️ 🔍
🟢	HR (lan)	em1		static	10.10.10.1/24			10.10.10.0/24	⚙️ 🔍
🟢	Finance (opt1)	em2		static	10.10.20.1/24			10.10.20.0/24	⚙️ 🔍
🟢	IT (opt2)	em3		static	10.10.30.1/24			10.10.30.0/24	⚙️ 🔍
🟢	Server (opt3)	em4		static	10.10.40.1/24			10.10.40.0/24	⚙️ 🔍
🟢	Guest (opt4)	em5		static	10.10.60.1/24			10.10.60.0/24	⚙️ 🔍
🟢	Managment (opt5)	em6		static	10.10.99.1/24			10.10.99.0/24	⚙️ 🔍

Showing 1 to 10 of 10 entries

Figure 3.1 — OPNsense Interfaces Overview, showing all six department interfaces each with a static /24 gateway address and an active route.

4. Virtual Network Design

The address plan implemented across the network is summarised below:

Department	Interface	Subnet	Gateway
HR	em1 (LAN)	10.10.10.0/24	10.10.10.1
Finance	em2 (opt1)	10.10.20.0/24	10.10.20.1
IT	em3 (opt2)	10.10.30.0/24	10.10.30.1
Server	em4 (opt3)	10.10.40.0/24	10.10.40.1
Guest	em5 (opt4)	10.10.60.0/24	10.10.60.1
Management	em6 (opt5)	10.10.99.0/24	10.10.99.1
VPN (WireGuard)	wg0	10.10.50.0/24	10.10.50.1

Each department's client VM(s) were connected to the matching VMnet in VMware, ensuring department traffic is physically isolated at the hypervisor level in addition to being logically segmented by OPNsense.

5. DHCP Configuration

Dynamic addressing was configured using OPNsense's Dnsmasq DNS & DHCP service. A distinct DHCP range was defined for each department interface so that client VMs automatically receive an address on power-on, rather than requiring manual static configuration.

Services: Dnsmasq DNS & DHCP

General Domains Hosts DHCP ranges DHCP options DHCP boot DHCP tags

Search Tags & Interfaces 50

☐ Interface	Start address	End address	Domain	Description	Commands
☐ HR	10.10.10.41	10.10.10.245			
☐ Finance	10.10.20.10	10.10.20.245			

Showing 1 to 2 of 2 entries

Apply

Figure 5 — DHCP ranges configured per department interface in Services: Dnsmasq DNS & DHCP.

6. Troubleshooting Network Interface Mapping

During implementation, a VMnet-to-interface mismatch was identified: client VMs cloned for the IT, Guest, and Management departments were found to be receiving DHCP leases from the wrong subnet (e.g. the IT client was receiving a Management-range address). This was traced to inconsistent VMnet assignment between OPNsense's virtual network adapters and the corresponding client VM network adapters.

The issue was resolved by:

- Documenting an explicit VMnet-to-department mapping as a single source of truth
- Verifying each OPNsense network adapter's VMnet assignment against Interfaces → Assignments
- Re-cloning affected client VMs with correct VMnet assignment and freshly generated MAC addresses
- Verifying each client's IP address individually before proceeding to the next department

This methodical, one-at-a-time verification approach prevented further cross-department mismatches for the remainder of the build.

7. Network Segmentation — VLAN Design and Access Control Lists (Firewall Rules)

7.1 Implementation Approach

OPNsense evaluates firewall rules per-interface, top-to-bottom, with first-match-wins semantics. Two reusable aliases were created to simplify rule management:

- `Internal_networks` — a network alias containing all six department subnets, used to block inter-department traffic in a single rule rather than one rule per department
- `Server_Required_Ports` — a port alias (445 SMB, 3306 MySQL, 80/443 HTTP/S) restricting HR and Finance's access to the Server segment to only the specific services required, rather than full access

For each interface, an “allow to self/gateway” rule was placed first (to preserve DNS and local gateway access), followed by specific allow rules for permitted destinations, a block rule for the Internal_networks alias, and the default allow-to-any rule last (governing internet access).

7.2 Rule Summary by Interface

Interface	Effective Policy
HR	Self + full Server access; blocked from Finance/IT/Guest/Management; internet allowed
Finance	Self + full Server access; blocked from HR/IT/Guest/Management; internet allowed
IT	Full access to HR, Finance, Server, Management; blocked from Guest; internet allowed
Server	Full access to IT & Management; port-restricted access to/from HR & Finance; blocked from Guest; internet limited to web/DNS ports
Guest	Self only; blocked from all internal departments; internet allowed
Management	Full access to all departments and internet (no restrictions)

8. Connectivity Verification

Each interface's rule set was verified from its corresponding client VM using ping, netcat (nc), and curl, confirming that actual traffic behaviour matched the intended access matrix rather than relying on configuration review alone.

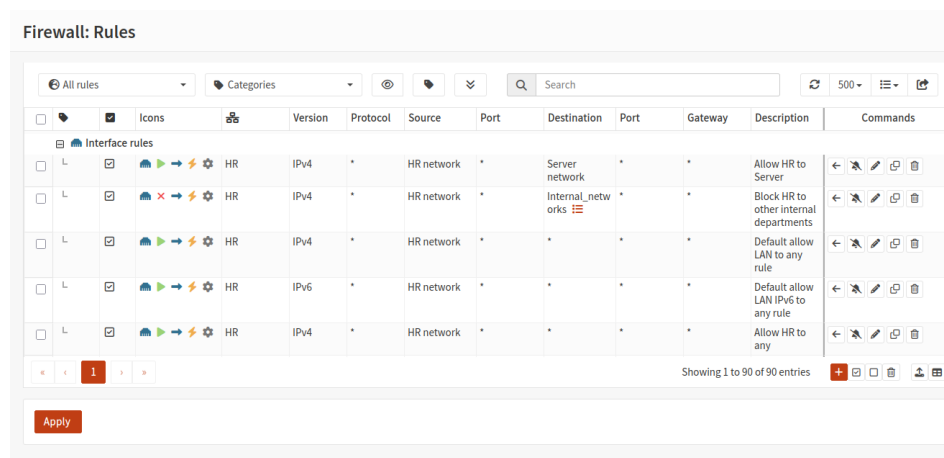


Figure 8.1 — HR client connectivity test: full access to the Server segment, blocked access to Finance, and confirmed internet access.

```

ak@buntuclient1:~$ ping -c 4 10.10.20.1
PING 10.10.20.1 (10.10.20.1) 56(84) bytes of data.
64 bytes from 10.10.20.1: icmp_seq=1 ttl=64 time=8.86 ms
64 bytes from 10.10.20.1: icmp_seq=2 ttl=64 time=0.778 ms
64 bytes from 10.10.20.1: icmp_seq=3 ttl=64 time=1.22 ms
64 bytes from 10.10.20.1: icmp_seq=4 ttl=64 time=0.830 ms

--- 10.10.20.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3037ms
rtt min/avg/max/mdev = 0.778/2.923/8.862/3.433 ms
ak@buntuclient1:~$ ping -c 4 10.10.40.43
PING 10.10.40.43 (10.10.40.43) 56(84) bytes of data.

--- 10.10.40.43 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3086ms

ak@buntuclient1:~$ ping -c 4 10.10.40.43
PING 10.10.40.43 (10.10.40.43) 56(84) bytes of data.

--- 10.10.40.43 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3100ms

ak@buntuclient1:~$ ping -c 4 10.10.10.117
PING 10.10.10.117 (10.10.10.117) 56(84) bytes of data.

--- 10.10.10.117 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3107ms

ak@buntuclient1:~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=116 time=27.8 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=116 time=27.6 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=116 time=24.8 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=116 time=25.2 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 24.827/26.378/27.845/1.351 ms

```

Figure 10.2 — HR client connectivity test, confirming the same allow/block/internet pattern applied to Finance.

The same test methodology (ping for allowed/blocked reachability, nc for port-level verification, curl for HTTP/internet access) was repeated for IT, Guest, Server, and Management, with each interface's observed behaviour matching its designed policy in the access matrix.

9. Enterprise Web Server Deployment

The Server segment (10.10.40.0/24) was populated with a client VM configured to act as the organisation's internal enterprise server, hosting three services matching the ports permitted in the firewall rules:

- Apache2 — web server, ports 80/443
- MySQL Server — database service, port 3306, configured to accept remote connections from permitted departments
- Samba — SMB file sharing, port 445, with a shared folder configured for department access

This gives the firewall's port-restricted HR/Finance → Server rules a real service to enforce against, rather than a simulated target, and demonstrates a realistic enterprise server footprint (file, database, and web services) within the segmented network.

10. NAT / Port Forwarding

To make the internally hosted web server reachable from outside the OPNsense network, a Destination NAT (port forwarding) rule was configured on the WAN interface, redirecting inbound TCP port 80 traffic to the Server VM (10.10.40.43:80). A corresponding WAN firewall rule was added to permit this inbound traffic.

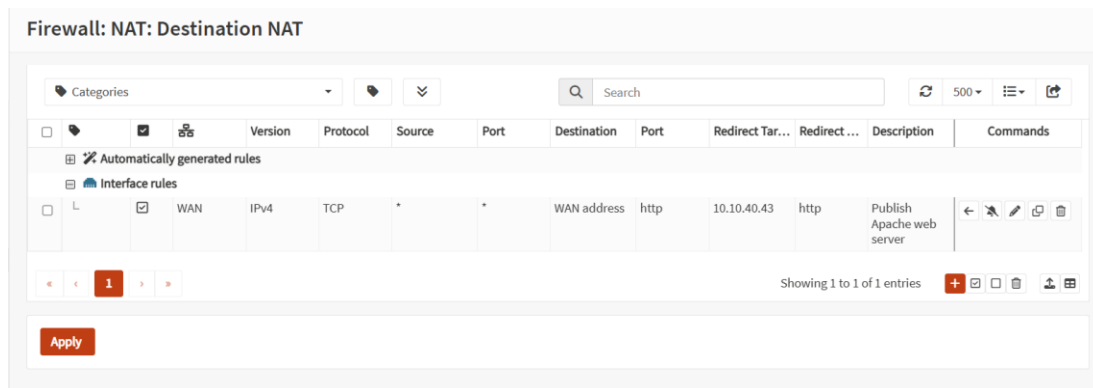


Figure 10.1 — Destination NAT rule publishing the internal Apache web server (10.10.40.43:80) via the WAN interface.

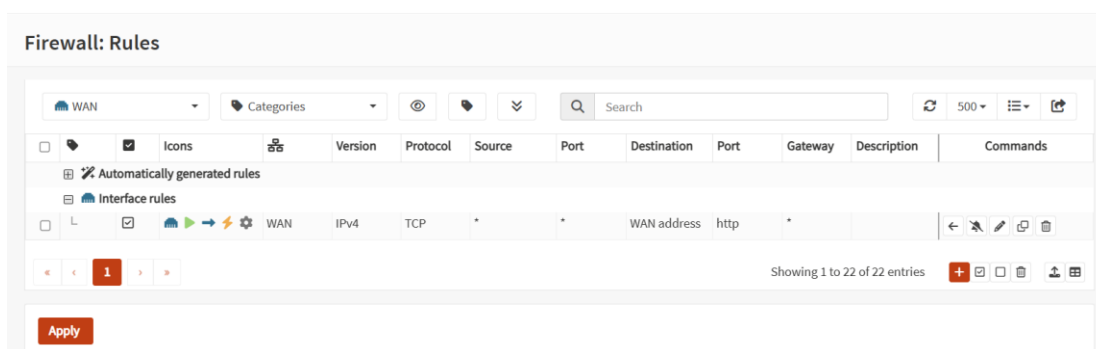


Figure 10.2 — Associated WAN firewall rule permitting inbound TCP traffic on port 80.

Internal reachability of the published service was confirmed from department clients (e.g. HR → Server via curl on port 80). External reachability testing from the physical host machine was also carried out; in a VMware Workstation lab environment this exercises the interaction between the hypervisor's virtual networking (NAT/Bridged adapter modes) and OPNsense's own WAN filtering — including OPNsense's default 'Block private networks' protection, which was identified and adjusted to permit private-range WAN traffic for this lab scenario.

11. Secure Remote Access — VPN Configuration (WireGuard) and Zero Trust Considerations

A WireGuard VPN server configuration was implemented on OPNsense as the foundation for secure remote employee access. The implementation included the WireGuard instance, peer configuration, dedicated VPN interface, and supporting firewall rules. End-to-end connectivity from an external WireGuard client was identified as a follow-on validation step.

11.1 Server-Side Configuration

- A WireGuard instance (wg0) was created with an auto-generated keypair, listening on UDP port 51820, using tunnel address 10.10.50.1/24
- A peer (RemoteEmployee1) was generated using OPNsense's built-in Peer generator, producing a matching client keypair and configuration, with allowed IP 10.10.50.2–3/32

- The WireGuard tunnel was assigned as a new OPNsense interface (VPN) and enabled
- A WAN firewall rule was added (via a dedicated WireGuard_Port alias) to permit inbound UDP 51820, and a VPN interface rule was added to allow authenticated VPN clients outbound access to internal resources

Advanced mode full help

Enabled ☒

Name wg0

Instance 0

Public key jly6PDyo4Qx5A4GFBBpNLkaLLH3S6JtLrqxEtyAL...

Private key W00DuyOEs5Z83oMchiKpqvlzKYXRsetbiMFy9yFC...

Listen port 51820

Tunnel address 10.10.50.1/24 Clear All Copy Paste Text

Depend on (CARP) None

Peers Nothing selected Clear All Select All

Disable routes ☐

Cancel Save

Figure 11.1 — WireGuard server instance (wg0) configuration: auto-generated keypair, UDP port 51820, tunnel address 10.10.50.1/24.

full help

Identifier

Lock ☒

Description VPN

Device wg0 (WireGuard - wg0)

Cancel Save

Figure 11.2 — The WireGuard tunnel (wg0) assigned as a dedicated VPN interface in OPNsense.

The WireGuard service, instance, peer, interface assignment, and firewall rules were all configured and verified as running on the OPNsense side. A live end-to-end connection test from an external WireGuard client was scoped as a follow-on validation step beyond the timeframe of this build cycle.

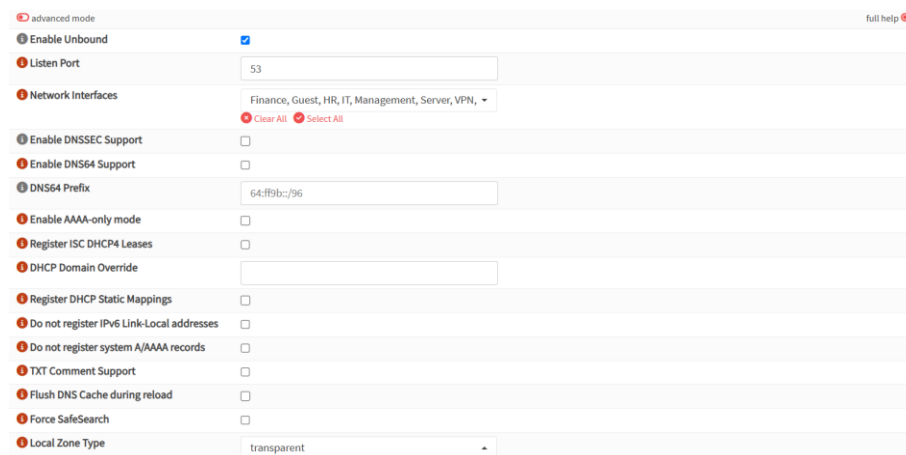
11.2 Zero Trust Considerations

The VPN was intentionally assigned its own dedicated interface and subnet (10.10.50.0/24) rather than being placed directly onto an existing department network, which allows VPN traffic to be governed by its own explicit firewall rule set the same least-privilege model used for every department in Section 8 instead of implicitly inheriting full internal trust simply by virtue of connecting. This is a foundational Zero Trust principle: network location (having a tunnel

established) is treated as authentication only, not as authorization to reach everything internally. In a production rollout, this should be extended by scoping the VPN interface's firewall rule to only the specific department resources a given remote employee's role requires (mirroring the RBAC plan in Section 14.2), rather than the current lab configuration's broader allow-any rule, and by pairing VPN connection with MFA as described in Section 14.1.

12. Unbound DNS Configuration

OPNsense's built-in Unbound resolver was enabled to provide internal DNS resolution across all department interfaces, including the VPN interface. Unbound was configured to listen on all department networks.



advanced mode full help

Enable Unbound ☒

Listen Port 53

Network Interfaces Finance, Guest, HR, IT, Management, Server, VPN,
Clear All Select All

Enable DNSSEC Support ☐

Enable DNS64 Support ☐

DNS64 Prefix 64:ff9b::96

Enable AAAA-only mode ☐

Register ISC DHCP4 Leases ☐

DHCP Domain Override

Register DHCP Static Mappings ☐

Do not register IPv6 Link-Local addresses ☐

Do not register system A/AAAA records ☐

TXT Comment Support ☐

Flush DNS Cache during reload ☐

Force SafeSearch ☐

Local Zone Type transparent

Figure 12.1 — Unbound DNS general settings: enabled on port 53, listening across all department interfaces plus VPN.

A host override was added, mapping `webserver.enterprise.local` to the internal Server VM (10.10.40.43), simulating a realistic enterprise internal DNS naming convention. Resolution was verified directly against the OPNsense DNS service from a client machine:

```
ak@ubuntuclient1:~$ nslookup webserver.enterprise.local 10.10.10.1
Server:      10.10.10.1
Address:     10.10.10.1#53

Name:   webserver.enterprise.local
Address: 10.10.40.43

ak@ubuntuclient1:~$ nslookup google.com 10.10.10.1
;; communications error to 10.10.10.1#53: timed out
Server:      10.10.10.1
Address:     10.10.10.1#53

Non-authoritative answer:
Name:   google.com
Address: 142.250.183.142
Name:   google.com
Address: 2404:6800:4007:811::200e
```

Figure 12.2 — Successful resolution of an external domain (`google.com`) via Unbound, confirming both internal and internet DNS resolution are functional.

13. Perimeter Security Validation — IDPS Evaluation and Security Testing with Kali Linux

13.1 Intrusion Detection and Prevention (IDPS)

OPNsense's Suricata-based Intrusion Detection and Prevention System was evaluated as part of the perimeter security implementation. Suricata was enabled on a monitoring interface, and the Emerging Threats Open ruleset was downloaded and loaded successfully.

The service was confirmed to start and process the configured ruleset. However, end-to-end validation involving the generation and capture of a live intrusion alert was not completed within the project timeframe.

OPNsense's stateful firewall functionality was separately implemented and validated through firewall rules, network segmentation, access-control testing, and Nmap-based security testing.

13.2 Security Testing Methodology

To validate that the firewall segmentation holds against active reconnaissance — not just simple connectivity checks — a Kali Linux VM was attached to the most restricted segment, Guest (10.10.60.0/24), and used to run Nmap scans against other department subnets.

13.3 Host Discovery Scans

Ping-sweep host discovery scans were run against both the HR (10.10.10.0/24) and Server (10.10.40.0/24) subnets from Kali, with target VMs confirmed powered on to ensure a valid test:

```
(bumblebee@kali)-[~]
$ sudo nmap -sn 10.10.10.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-22 07:23 -0400
Nmap done: 256 IP addresses (0 hosts up) scanned in 206.34 seconds
```

Figure 13.3 — Nmap host-discovery scan of the HR subnet from Kali (Guest network)

An identical result (0 hosts up) was observed when scanning the Server subnet, confirming consistent enforcement across all blocked destinations.

13.4 Port-Level Scan

A targeted port scan (with host-discovery bypassed via -Pn) was run directly against the Server VM's known IP address on the ports it serves (80, 443, 445, 3306):

```
(bumblebee@kali)-[~]
$ sudo nmap -Pn -p 80,443,445,3306 10.10.40.43
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-22 07:42 -0400
Nmap scan report for webserver.enterprise.local (10.10.40.43)
Host is up.

```

PORT	STATE	SERVICE
80/tcp	filtered	http
443/tcp	filtered	https
445/tcp	filtered	microsoft-ds
3306/tcp	filtered	mysql

```

Nmap done: 1 IP address (1 host up) scanned in 3.40 seconds
(bumblebee@kali)-[~]
$ curl -i http://8.8.8.8
curl: (7) Failed to connect to 8.8.8.8 port 80 after 3062 ms: Could not connect to server
```

Figure 13.4 — Direct port scan of the Server VM from Kali/Guest: all four ports report as filtered, confirming the firewall is actively dropping Guest-originated packets rather than the host being merely absent.

The 'filtered' state (rather than 'closed') is significant: it demonstrates OPNsense is silently dropping Guest-to-Server traffic at the firewall, which is the intended behaviour per the access matrix. This constitutes direct evidence, using an industry-standard security tool, that the network's segmentation design is correctly enforced against unauthorised internal reconnaissance.

14. Identity and Access Management (IAM) Plan

Multi-Factor Authentication (MFA) and Role-Based Access Control (RBAC) were assessed for this deployment and are documented here as a configuration plan. Full IAM rollout typically follows once core network segmentation (Sections 2–8) is stable, which this project prioritised within the available timeframe.

14.1 Multi-Factor Authentication (MFA)

- OPNsense administrative access (the web UI used to manage the firewall) is recommended to be protected with TOTP-based MFA, configured under System → Access → Users, using an authenticator app (e.g. Google Authenticator, Authy) per administrator account
- The current WireGuard implementation uses cryptographic key-based authentication. For a production environment, additional identity verification and MFA should be considered through an appropriate identity-aware remote-access architecture. MFA integration was not implemented or validated as part of this project.
- Captive-portal-based MFA is recommended for the Guest network if guest registration/sponsorship is required in a production deployment

14.2 Role-Based Access Control (RBAC)

- OPNsense's built-in User & Group Privilege system is recommended to define distinct administrative roles: e.g. a 'Network-Admin' group with full configuration rights, and a 'Read-Only-Auditor' group limited to viewing logs and configuration without edit rights
- At the department level, the firewall rule structure implemented in Section 7 already enforces a form of network-layer RBAC: each department's traffic is scoped to only the destinations and ports its role requires (e.g. HR and Finance are restricted to specific Server ports rather than full access, while Management retains full access reflecting an administrative role)
- For application-level RBAC on the enterprise server (Section 9), it is recommended that MySQL user accounts be created per application/department with GRANT privileges scoped to only the databases/tables required, rather than using the root account for day-to-day access

15. Endpoint Security Plan

Endpoint protection was scoped as a policy/planning deliverable for this engagement, since deploying and centrally managing endpoint agents across a fleet of devices is typically an organisation-wide rollout distinct from the core network build. The following plan is recommended for production implementation:

- Deploy a centrally managed Endpoint Detection and Response (EDR) agent (e.g. Microsoft Defender for Endpoint, CrowdStrike Falcon, or an open-source equivalent such as Wazuh) on every corporate-owned device across all six departments
- Enforce baseline antivirus/anti-malware protection on all endpoints, with signature updates verified centrally rather than left to individual devices
- Implement a Device Compliance check (e.g. via the EDR agent or a NAC solution) that verifies OS patch level, antivirus status, and disk encryption state before an endpoint is granted a DHCP lease or VPN session — devices failing compliance would be redirected to a remediation VLAN rather than the department network
- Extend the Guest network's existing internet-only, fully-isolated firewall policy (Section 7) to also serve as the default landing segment for any endpoint that fails its compliance check, so non-compliant devices are automatically contained using infrastructure already built in this project

16. Data Encryption Strategy

16.1 Encryption in Transit

Encryption in transit is already implemented by two components built in this project, rather than requiring separate work: the WireGuard VPN (Section 11) uses modern authenticated encryption for all remote-access traffic by design, and the enterprise web server (Section 11) has Apache's SSL module enabled to serve traffic over HTTPS/443 using TLS. It is recommended that, in a production rollout, a certificate from a trusted internal or public Certificate Authority replace the self-signed lab certificate, and that plain HTTP (port 80) be restricted to a redirect-to-HTTPS rule only.

16.2 Encryption at Rest

Encryption at rest was not implemented within this project's timeframe and is documented here as a guideline for production deployment:

- Full-disk encryption (e.g. LUKS on Linux servers, BitLocker on Windows endpoints) is recommended for the Server VM and any device storing department data, particularly the MySQL database and Samba file share configured in Section 9
- MySQL's native Transparent Data Encryption (TDE) or filesystem-level encryption is recommended for the database data directory specifically, given it holds structured enterprise records
- Encryption key management should be centralised (e.g. via a dedicated key management service) rather than stored alongside the encrypted volumes themselves

17. Monitoring and Logging Plan

Network monitoring and logging were implemented and actively used throughout this project as the primary diagnostic and verification mechanism, rather than being a separate afterthought. OPNsense's Firewall → Log Files (Live View) was used repeatedly to confirm, in real time, which rule was matching a given connection attempt — this same logging capability is the foundation of an enterprise monitoring deployment.

- Live firewall logging is enabled by default on OPNsense and was used throughout Sections 7–13 to verify rule behaviour, diagnose misconfigurations, and confirm the Kali/Nmap security testing results
- OPNsense's Reporting → Insights module (built on Netflow/Flowd) is recommended to be enabled for longer-term traffic trend analysis beyond the live log view used during this build
- For centralised logging in a multi-site production deployment, it is recommended that OPNsense's syslog output be forwarded to a central SIEM (e.g. an ELK/OpenSearch stack, Splunk, or Graylog) rather than relying on each site's local log storage, enabling correlation of events across the whole enterprise rather than per-location
- Suricata's IDS logging (Section 13.1), once fully validated, should also be forwarded to the same central SIEM so that intrusion alerts and firewall-block events can be correlated together

18. Policy and Compliance Documentation

18.1 Security Policy Summary

The following policy statements are recommended to formalise the technical controls implemented in this project:

- Least-privilege access: department network access is restricted by default; access to another department's resources requires an explicit, documented business justification and firewall rule change (as implemented in Section 8)
- Remote access: all remote access to internal resources must be via the approved VPN (Section 11); direct exposure of internal services to the WAN is prohibited except where explicitly published and approved (as controlled in Section 10)
- Change control: firewall rule changes should be reviewed and logged rather than applied ad hoc in production, unlike the iterative lab process used during this build
- Acceptable use: the Guest network (Section 7) is internet-only by design and must never be granted access to internal department resources

18.2 Regulatory Compliance Considerations

As an energy and utilities sector organisation, the following regulatory considerations are relevant and are mapped to controls in this report:

The following mapping is provided for high-level educational consideration only. It identifies how selected security controls in the lab may support broader regulatory or security requirements and does not represent a formal compliance assessment or certification.

Requirement Area	Relevant Controls in This Report
Data protection (GDPR)	Network segmentation (Sec. 7) limiting data exposure; encryption in transit (Sec. 16.1); recommended encryption at rest (Sec. 16.2)
Access control & audit (GDPR, HIPAA-equivalent)	RBAC plan (Sec. 14.2); firewall logging (Sec. 17); least-privilege department policy (Sec. 18.1)
Critical infrastructure protection (e.g. NERC CIP for energy sector)	Perimeter firewall/NGFW (Sec. 3, 7); segmented Server/SCADA-equivalent zone; IDPS evaluation (Sec. 13.1)
Breach notification readiness	Centralised logging plan (Sec. 17); Incident Response Plan (Sec. 19 following)

A full compliance audit against specific regulatory frameworks (e.g. formal NERC CIP or GDPR Article 32 assessment) was outside the scope and timeframe of this project and is recommended as a dedicated follow-on engagement.

19. Incident Response Plan

19.1 Incident Response Process

- Detection: alerts sourced from OPNsense firewall logs (Sec. 18), Suricata IDS (Sec. 14.1), and EDR endpoint alerts (Sec. 16) are triaged by the on-call network/security responder
- Containment: the responder isolates the affected segment using the same firewall rule mechanism validated in Section 8 — for example, temporarily reassigning an affected department's block rule to deny all traffic (not just inter-department) pending investigation, or redirecting the affected VLAN to the Guest-equivalent isolated segment
- Eradication & Recovery: affected endpoints are re-imaged or cleaned per the EDR plan (Sec. 16), credentials are rotated for any account plausibly exposed, and the department's normal firewall rules are restored only after verification
- Post-incident review: firewall and IDS logs (Sec. 18) are reviewed to build a timeline, and the departmental access matrix (Sec. 8) is re-assessed for any policy gap the incident revealed

19.2 Incident Response Drill Scenario

A tabletop drill is recommended using the following scenario, directly exercising the infrastructure built in this project: a simulated attacker gains a foothold on a Guest-network device and attempts to pivot into the HR and Server segments, mirroring the exact Nmap-based test performed in Section 14. The response team's objective is to detect the scan attempt via firewall/IDS logging (Sec. 18), confirm containment is already enforced (as demonstrated by the 'filtered' Nmap results in Section 13.4), and document the incident using the process in Section 19.1 — providing a low-

risk, repeatable way to rehearse the response process against a known-good baseline before a real incident occurs.

20. Conclusion

20.1 Summary of Outcomes

This project delivered a fully segmented, six-department enterprise network with centralised firewall enforcement, DHCP provisioning, an internally hosted multi-service enterprise server, externally published web access via NAT, server-side WireGuard VPN configuration for planned secure remote access, internal DNS resolution via Unbound, and independent security validation using Kali Linux and Nmap. The build progressed through eight distinct phases — environment setup, firewall installation, network design, DHCP configuration, interface-mapping troubleshooting, access-control rule implementation, connectivity verification, and enterprise service deployment — with each phase building directly on the one before it, mirroring how a real enterprise network rollout would be sequenced and validated stage by stage rather than deployed all at once.

Critically, every stage of the network was validated through live testing rather than configuration review alone. Firewall rules were tested with ping, netcat, and curl from each department's own client; DNS resolution was confirmed against both an internal host override and an external domain; the VPN service was confirmed running end-to-end on the OPNsense side; and, most significantly, the firewall's segmentation policy was independently verified using Nmap from a Kali Linux attack host — with all scanned ports returning a 'filtered' state rather than merely appearing absent. This distinction matters: a filtered response demonstrates that OPNsense is actively intercepting and dropping unauthorised traffic, which is materially stronger evidence of a working security control than a simple lack of response would be.

20.2 Key Technical Achievements

- Designed and implemented a six-segment private addressing scheme (10.10.x.0/24) with clean separation between HR, Finance, IT, Server, Guest, and Management traffic
- Diagnosed and resolved a non-trivial VMnet-to-firewall-interface mapping fault affecting three departments simultaneously, restoring correct DHCP behaviour across the network
- Translated a plain-language departmental access-control matrix into a working, alias-based OPNsense rule set enforcing least-privilege access between all six departments
- Deployed and hardened a realistic three-service enterprise server (Apache, MySQL, Samba) with port-level access restrictions rather than blanket allow rules
- Established outbound and inbound NAT (Destination NAT / port forwarding) to publish an internal service externally, including diagnosing and correcting OPNsense's default reserved-network WAN protection
- Stood up a WireGuard VPN server instance with a generated peer configuration, dedicated interface, and supporting firewall rules for secure remote access
- Configured Unbound as the authoritative internal resolver with a custom host override, while preserving external DNS resolution
- Independently validated the entire access-control model using an industry-standard offensive security tool (Nmap via Kali Linux), rather than relying solely on the same firewall's own logs as evidence of its correctness

20.3 Challenges Encountered

The build surfaced several realistic troubleshooting scenarios rather than proceeding as a purely linear checklist, which is itself a useful reflection of enterprise network operations. Notable issues included: a department-to-department IP range mismatch traced to cloned VMs inheriting incorrect VMnet assignments; an over-broad firewall block rule that inadvertently cut a department off from its own gateway and DNS resolver; OPNsense's default 'Block private networks' WAN protection silently discarding legitimate lab traffic during NAT testing; and a stale duplicate IP/default route on the Kali attack host that prevented outbound traffic from ever reaching the firewall for evaluation. Each issue was isolated methodically using OPNsense's live state table and firewall logs rather than trial-and-error, which is the same diagnostic approach used in production network troubleshooting.

20.4 Limitations and Recommended Next Steps

A small number of items were identified during the build but intentionally deferred beyond its scope due to time constraints, and are recommended as follow-on work:

- Full end-to-end WireGuard connectivity testing from a genuine external client device (the server-side configuration was completed and verified running, but a live remote-to-internal session was not captured)
- Deployment of Suricata IDS/IPS for deep packet inspection and intrusion alerting, which was evaluated but excluded from the final build to prioritise core segmentation and access-control deliverables
- Migration of the externally published web server into a dedicated DMZ segment, isolated from the internal Server subnet, in line with enterprise security best practice for internet-facing services
- Formal traffic shaping/QoS policy per department, and centralised log aggregation for long-term audit and compliance reporting

Taken together, this project demonstrates the full lifecycle of enterprise network design: requirements translation (the access matrix), infrastructure build-out, systematic troubleshooting, security-policy enforcement, service delivery, and independent verification — providing a solid, evidence-backed foundation that could be extended toward a production-representative deployment.

21. References

The following tools, platforms, and documentation resources were used in the design, implementation, and testing of this network:

- OPNsense Project. OPNsense Documentation. <https://docs.opnsense.org/>
- OPNsense Project. OPNsense Firewall — Open Source Firewall and Routing Platform. <https://opnsense.org/>
- Broadcom / VMware. VMware Workstation Pro Documentation. <https://docs.vmware.com/en/VMware-Workstation-Pro/>
- Canonical Ltd. Ubuntu Server Documentation. <https://ubuntu.com/server/docs>
- The Samba Team. Samba Documentation — SMB/CIFS File and Print Server. <https://www.samba.org/samba/docs/>
- Oracle Corporation. MySQL 8.0 Reference Manual. <https://dev.mysql.com/doc/>
- The Apache Software Foundation. Apache HTTP Server Documentation. <https://httpd.apache.org/docs/>
- WireGuard. WireGuard: Fast, Modern, Secure VPN Tunnel — Official Documentation. <https://www.wireguard.com/>
- NLnet Labs. Unbound — Validating, Recursive, Caching DNS Resolver Documentation. <https://unbound.docs.nlnetlabs.nl/>
- Simon Kelley / Dnsmasq Maintainers. Dnsmasq — Lightweight DNS/DHCP Server Documentation. <https://thekelleys.org.uk/dnsmasq/doc.html>
- Nmap Project (Gordon 'Fyodor' Lyon). Nmap Network Scanning — Official Nmap Reference Guide. <https://nmap.org/book/>
- Offensive Security. Kali Linux Documentation. <https://www.kali.org/docs/>